UNIVERSIDAD DE LA SABANA · ARQUITECTURA EMPRESARIAL (AREM)

Arquitectura Empresarial TO-BE y Gobernanza para Insuclínicos Ltda.

Defensa de la Transición de Arquitectura: Del Excel aislado y papel en planta hacia plataforma Cloud unificada con trazabilidad sanitaria INVIMA.

Cliente: Insuclínicos Ltda. (Bogotá) · Rep. Legal: Santiago Martínez · 6 trabajadores · ~40 clínicas
Equipo Consultor: Jorge Steven Doncel Bejarano & David Santiago Buendía Londoño (Grupo 8)
Marco Metodológico: TOGAF ADM & ArchiMate 3.2

Comité de Arquitectura Empresarial · Sustentación Ejecutiva (10 min)

RESUMEN EJECUTIVO DE LA PROPUESTA

INVERSIÓN ANUAL
~$2.2M COP

Dentro del tope <= $3.0M COP/año (Odoo/Dolibarr)

HORIZONTE DE CAMBIO
12 Semanas

4 Work Packages graduales sin parar producción

SALTO NORMATIVO
13.3% → 100%

De 2/15 controles a trazabilidad INVIMA + Ley 1581

RIESGOS CONSOLIDADOS
10 Riesgos

7 dominios · 4 críticos mitigados · R10 aceptado

PyME manufacturera de ropa quirúrgica SMS en Bogotá con alta exigencia sanitaria y presupuesto acotado

6 Trabajadores

Operación multifuncional: ventas, confección, almacén y despacho.

~40 Clínicas y Spas

Base B2B recurrente en salud con pedidos semanales y alta rotación.

Tela Quirúrgica SMS

Insumo crítico por rollo y lote sujeto a regulación INVIMA.

<= $3.0M COP/año

Techo presupuestal estricto en licenciamiento SaaS y soporte.

Restricciones Innegociables de Negocio

- Continuidad operativa: Transición gradual sin detener un solo día la planta ni los despachos.
- Reúso de activos: Aprovechar computadores Windows actuales y conectividad PyME.
- Curva mínima: Operación intuitiva sin equipo interno de sistemas.

Objetivos Estratégicos de Negocio

OE-01 · Capacidad y Eficiencia de Producción

Eliminar órdenes verbales y papel hacia confección; recuperar ~6 h/sem de reprocesos.

OE-02 · Control de Inventario y Tela SMS en Tiempo Real

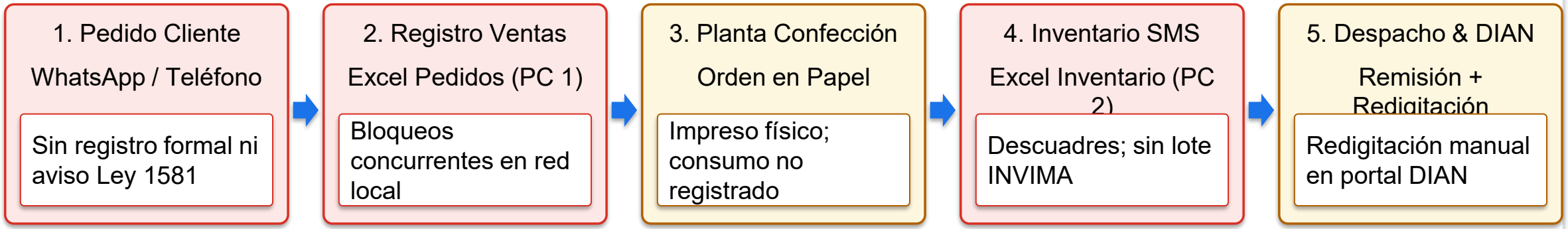
Sincronizar stock registrado con consumo real en corte y confección; cero paradas por stock.

OE-03 · Trazabilidad INVIMA y Facturación DIAN

Vincular pedido → lote SMS → remisión hospitalaria y emisión electrónica DIAN sin redigitar.

Flujo operativo fragmentado entre WhatsApp, dos archivos Excel en red y órdenes en papel

FLUJO OPERATIVO AS-IS Y PUNTOS DE QUIEBRE DE INFORMACIÓN



Dos Silos Excel en Red Local

2–3 Bloqueos / Día

Ventas e inventario en libros separados sin integridad referencial; bloqueos concurrentes de solo-lectura y versiones en conflicto.

Doble Digitación y Reprocesos

~6 Horas / Semana

Pérdida de tiempo reescribiendo pedidos en Excel, notas en papel y digitando facturas una a una en el portal DIAN.

Riesgo Sancionatorio Sanitario

0% Trazabilidad Lote

Sin vínculo bidireccional entre el lote de rollo SMS recibido del proveedor y la remisión entregada a cada clínica.

Arquitectura de Aplicaciones: Shadow IT Crítico

- Canales informales: Pedidos y comprobantes por WhatsApp sin integración con el ERP.
- Sin servidor ni BD: Dos archivos .xlsx compartidos por red Windows hacen de base de datos.
- Planta desconectada: Confección opera a ciegas recibiendo papel y reportando de palabra.
- Facturación manual: Transcripción manual de datos hacia el portal gratuito DIAN.

CONCLUSIÓN ESTRATÉGICA:

El negocio creció a ~40 clínicas usando herramientas domésticas; cualquier aumento de pedidos multiplica errores y retrasos.

Topología de Infraestructura: 3 Zonas con SPOF

Zona Nube Externa

WhatsApp Web, Gmail y portal DIAN aislados; cero respaldo de negocio externo.

Zona Oficina LAN — PUNTO ÚNICO DE FALLA (SPOF)

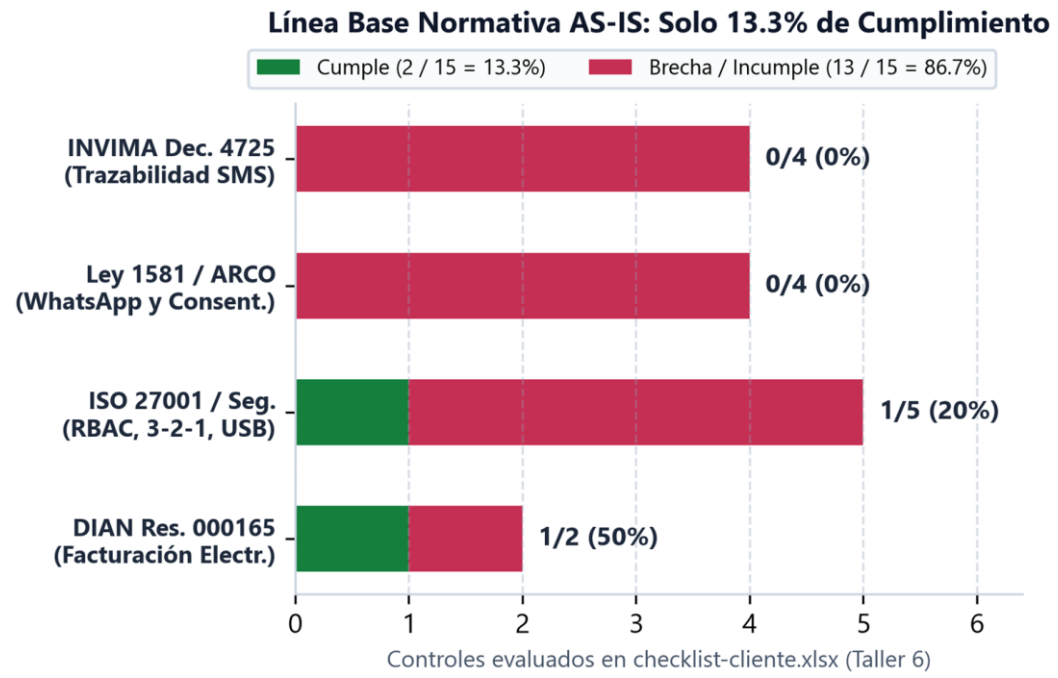
3 PCs y 1 solo disco duro local con los archivos Excel; sin backup 3-2-1 ni control de accesos.

Zona Planta de Confección

Sin cobertura de red ni terminales digitales; dependencia total de planillas físicas.

Exposición crítica de activos y solo 13.3% de cumplimiento normativo en el estado actual

Auditoría Normativa Base (13.3% de Cumplimiento)



Alerta Crítica: Cero trazabilidad de lote SMS (INVIMA Dec. 4725) y recolección de datos en WhatsApp sin autorización de Habeas Data (Ley 1581 de 2012).

Amenazas Críticas de Seguridad (Modelo STRIDE)

T5 · DoS / Pérdida Total (Nivel Crítico)

Fallo físico o ransomware en el único disco local paraliza la empresa y borra el historial.

T2 / T3 · Tampering y Repudio (Nivel Alto)

Cualquier usuario puede alterar inventario o precios en Excel sin registro de auditoría (audit_log).

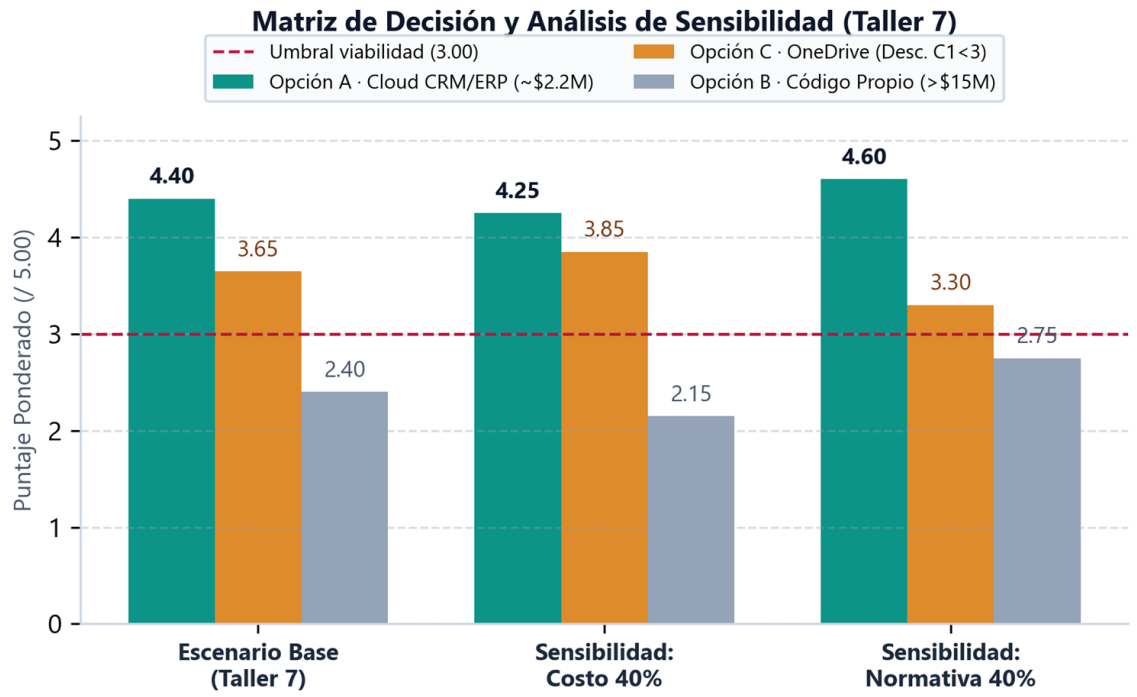
T1 · Spoofing por Cuentas Genéricas (Nivel Alto)

Sesiones compartidas en Windows impiden identificar quién realizó cada transacción.

T4 / T6 · Fuga de Información USB y Red (Nivel Alto)

Puertos USB abiertos y carpetas de red sin cifrado exponen datos comerciales de las clínicas.

Matriz Multicriterio y Análisis de Sensibilidad



Descarte justificado: Opción B (Desarrollo propio) supera 5x el presupuesto (>$15M/año); Opción C (OneDrive) no garantiza la trazabilidad inmutable que exige INVIMA.

Solución Seleccionada (Opción A · Puntaje 4.40 / 5.00)

- Core ERP/CRM Cloud: Odoo Community / Dolibarr sobre PostgreSQL (~$2.2M COP/año; 27% bajo el tope).
- Pedidos y Stock Unificados: Reserva automática de tela SMS al confirmar el pedido; fin de bloqueos en red.
- Cumplimiento INVIMA y DIAN: Campo obligatorio de lote SMS en remisión PDF y exportador estructurado DIAN.
- Seguridad y Respaldo: Cifrado TLS, 6 usuarios nominales con RBAC y respaldo diario automático 3-2-1.

DECISIÓN DE ARQUITECTURA (ADR #1):

Priorizamos software SaaS estándar sobre desarrollo a medida: garantiza costo de $2.2M COP/año, reusa los PCs actuales y permite salir a producción en 12 semanas sin riesgo técnico.

Integración vertical en 5 capas cerrando 10 brechas en 3 flujos punta a punta (E2E)

Tablero de Arquitectura TO-BE: 5 Capas

1. Negocio: Pedido formal, orden de confección digital y despacho con lote verificado.

2. Datos: PostgreSQL centralizado con catálogo maestro, trazabilidad SMS y audit_log inmutable.

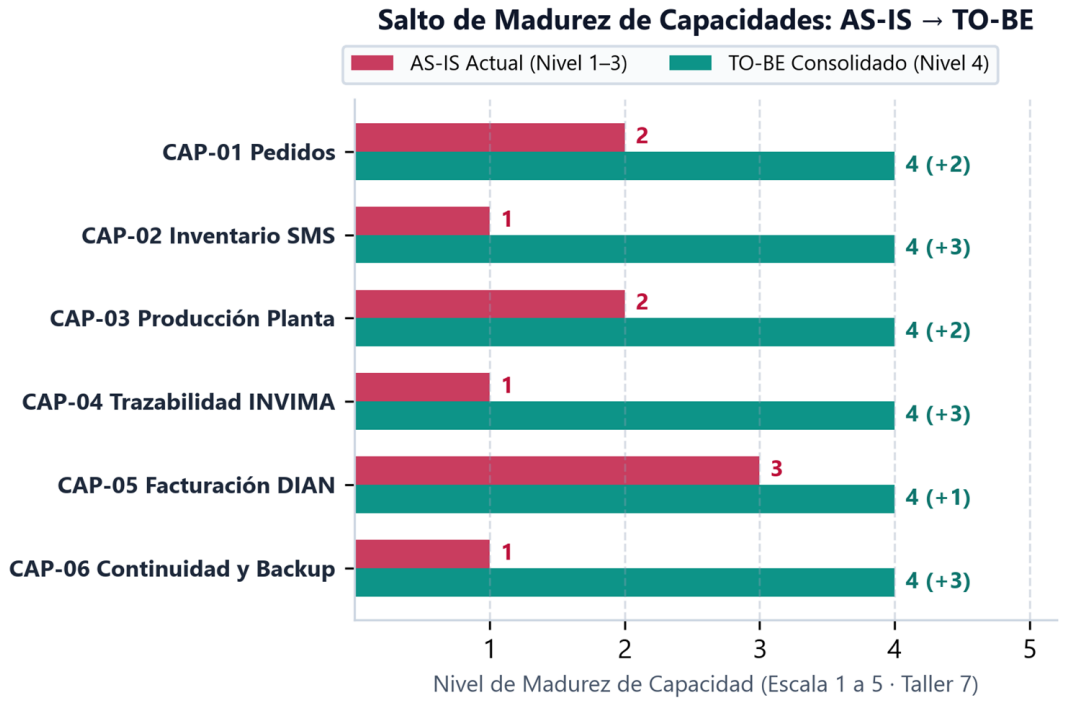
3. Aplicaciones: ERP Cloud multi-módulo, interfaz web para Tablet en planta y exportador DIAN.

4. Infraestructura: Servidor Cloud administrado, PCs actuales, Tablet Wi-Fi WPA3 y backup 3-2-1.

5. Seguridad y Legal: RBAC para 6 usuarios, TLS 1.3, cierre de puertos USB, Ley 1581 e INVIMA.

3 FLUJOS PUNTA A PUNTA (E2E) VALIDADOS:
- Flujo 1: Pedido cliente con autorización Ley 1581 → Reserva automática de rollo SMS en BD.
- Flujo 2: Tablet en Planta registra consumo → Asigna lote INVIMA → Genera remisión clínica PDF.
- Flujo 3: Remisión confirmada → Exportación estructurada a facturación DIAN sin redigitación.

Salto de Madurez de Capacidades de Negocio



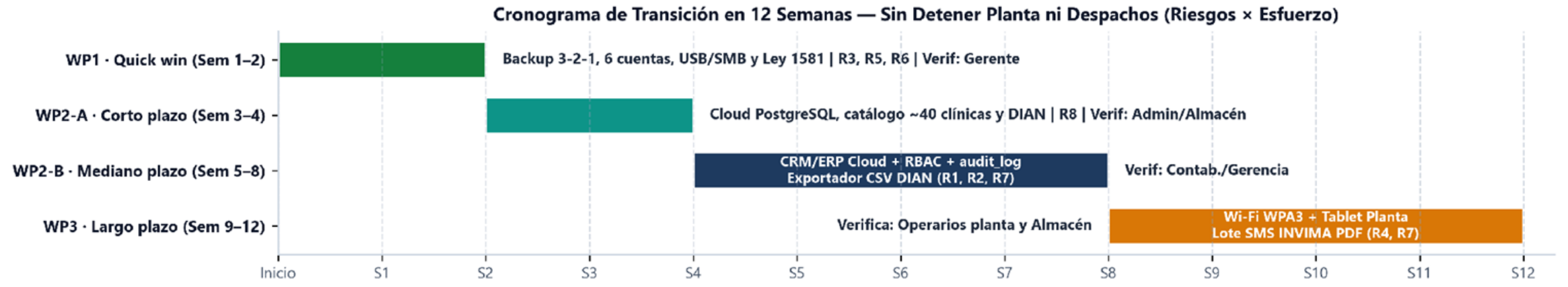
Cierre total de brechas: Las 10 brechas operativas identificadas se resuelven completamente a través de los 4 paquetes de trabajo de la hoja de ruta.

ID	Riesgo Arquitectónico	Dominio	Niv.	Estrategia	Control Bow-Tie	Fase Plan
R1	Silos Excel y bloqueos concurrentes en red	Aplicaciones	9	Eliminar	Preventivo	WP2-B Mediano
R2	Alteración o repudio de datos sin auditoría	Seguridad	9	Reducir	Prev. + React.	WP2-B Mediano
R3	Punto único de falla en disco local y ransomware	Infraestructura	8	Reducir	Reactivo (3-2-1)	WP1 Quick win
R4	Sin trazabilidad de lotes SMS (INVIMA Dec. 4725)	Gobierno TI	8	Eliminar	Preventivo	WP3 Largo
R5	Gestión en WhatsApp sin aviso Ley 1581 / ARCO	Gobierno TI	6	Eliminar	Preventivo	WP1 Quick win
R6	Cuentas genéricas, puertos USB y carpetas SMB abiertas	Seguridad	6	Reducir	Preventivo	WP1 Quick win
R7	Órdenes en papel y redigitación manual en DIAN	Procesos	6	Reducir	Preventivo	WP2-B / WP3
R8	Maestros de clientes (~40) y stock SMS duplicados	Datos	4	Reducir	Preventivo	WP2-A Corto
R9	Dependencia de proveedor ISP y equipo de 6 personas	Negocio	3	Transferir	Reactivo (SLA)	Gobernanza
R10	Falla física temporal de PC en bodega	Infraestructura	2	Aceptar *	Reactivo	Gobernanza

ESTRATEGIA BOW-TIE Y SECUENCIACIÓN:

Combinamos barreras preventivas y contención reactiva. Priorizamos victorias tempranas de seguridad y respaldo en las primeras 2 semanas mientras se parametriza la plataforma Cloud.

* RIESGO R10 ACEPTADO ESTRATÉGICAMENTE (NIVEL 2): Se descarta comprar un PC de reserva local por restricción presupuestal. Al operar 100% en la nube, ante cualquier fallo físico los operarios acceden de inmediato desde cualquier equipo o celular vía navegador.



Plan de Gestión del Cambio (Modelo ADKAR) para los 6 Colaboradores

Grupo Real (6 pers.)	Qué pierde o teme / Resistencia	Poder / Interés	Acción, Capacitación y Momento	Resultado Visible (Fuera de TI)
Operarios confección (2 pers.)	Temor a complicaciones con la Tablet; preferencia por papel.	Bajo / Alto	Práctica guiada de 45 min con lotes reales + marcha blanca en Sem 9.	Orden y lote SMS leídos en Tablet sin imprimir papel.
Auxiliar Ventas / Admin (1 pers.)	Miedo a lentitud del ERP y tentación de reabrir Excel.	Medio / Alto	Sesión práctica de 60 min + operación paralela en Sem 5; bloqueo de Excels.	Cero bloqueos diarios y generación de archivo DIAN en <5 min.
Encargado Almacén (1–2 pers.)	Temor a reclamos por descuadres históricos de tela SMS.	Medio / Alto	Inventario conjunto sin sanciones antes de migrar datos en Sem 3–4.	Remisión PDF emite lote SMS y registro INVIMA al instante.
Gerente / DPO (Santiago M.)	Riesgo de gastar > $3M/año sin control efectivo del negocio.	Alto / Alto	Tablero gerencial de 1 pág. con indicadores semanales M1–M3.	Respaldo 3-2-1 verificado y cumplimiento formal Ley 1581 e INVIMA.

Principios y Comité Ligero

P1 · Sobriedad y Reúso: Solución SaaS <= $3M/año y reuso de PCs; prohíbe código a medida.
P2 · Fuente Única INVIMA: Base PostgreSQL central; prohíbe Excels paralelos y exige lote SMS.
P3 · Seguridad Pragmática: 6 usuarios nominales con RBAC, backup 3-2-1 y aviso Ley 1581.
Principio Retirado: Se descarta mantener Excels en paralelo tras la semana 8.

COMITÉ Y OPERACIÓN TO-BE:

- 3 Integrantes: Gerencia (Santiago M.), Arquitecto Líder y Seguridad/Planta.
- Sesión: Quincenal durante las 12 semanas y semestral en régimen ordinario.
- Regla: Cualquier excepción tecnológica exige un ADR aprobado en <= 5 días.

Registro de Decisiones (ADRs) y Cambios

ADR #1 · ERP Cloud sobre PostgreSQL (Aprobada)
Adopta Odoo/Dolibarr Cloud (~$2.2M) y descarta desarrollo propio (>$15M). Acepta interfaz estándar a cambio de bajo costo, rapidez y cero bloqueos.

ADR #2 · Tablet Planta y Conector DIAN (Aprobada)
Tablet Wi-Fi WPA3 con captura obligatoria de lote y exportador CSV DIAN. Pospone API DIAN directa para fase posterior al crecer el volumen.

Disparadores de Revisión:
Cambio normativo INVIMA/DIAN, incidente de seguridad o crecimiento superior al 30% en pedidos.

3 Métricas de Gobernanza

M1 · Adopción de Fuente Única (P2)
Transacciones en PostgreSQL ÷ totales × 100.
Meta: 100% en Semana 12 (Alerta si <80% en Sem 8).

M2 · Cumplimiento Regulatorio (P3)
Controles verificados ÷ 15 × 100.
Meta: 100% en Semana 12 (Base actual: 13.3%).

M3 · Agilidad del Comité (Gobierno)
Días hábiles entre propuesta y dictamen de ADR.
Meta: <= 5 días hábiles (<24h si es urgente).

IMPACTO FINAL PARA EL CLIENTE

- ~6 h/sem recuperadas · 0 bloqueos en red
- Trazabilidad total de lote SMS en remisión PDF
- Inversión ~$2.2M/año (Tope <= $3.0M) · 0 paradas de planta